



# Secure Software Engineering

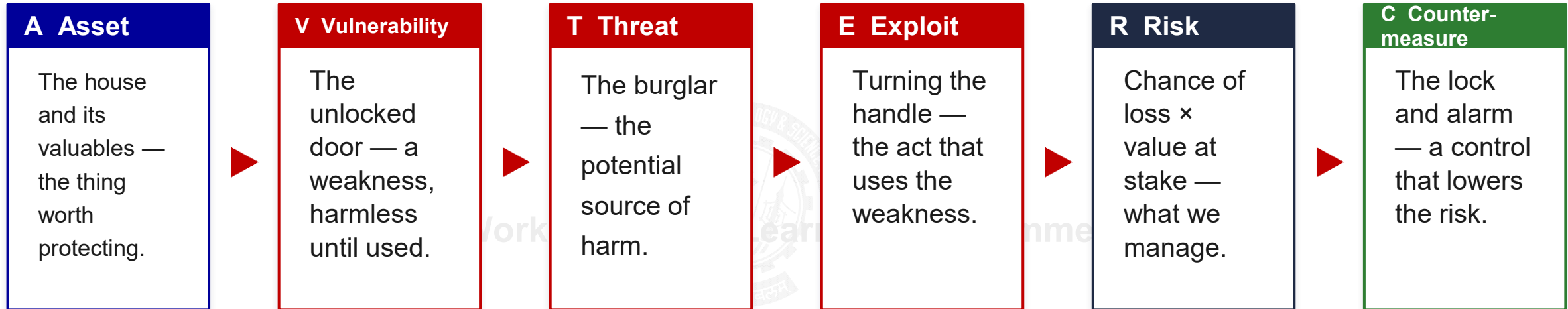


## Core Definitions, Concepts & Examples

# The five terms and how they relate — the burglary model



Read left to right. Each term is defined in relation to the one before it; the last is how we respond.



In one sentence: a **threat** agent uses an **exploit** against a **vulnerability** in an **asset**; the **risk** is the expected loss, which a **countermeasure** reduces.  
Source: Burglary analogy after Stallings & Brown (T2)

# What is Security?

---

What does it mean?

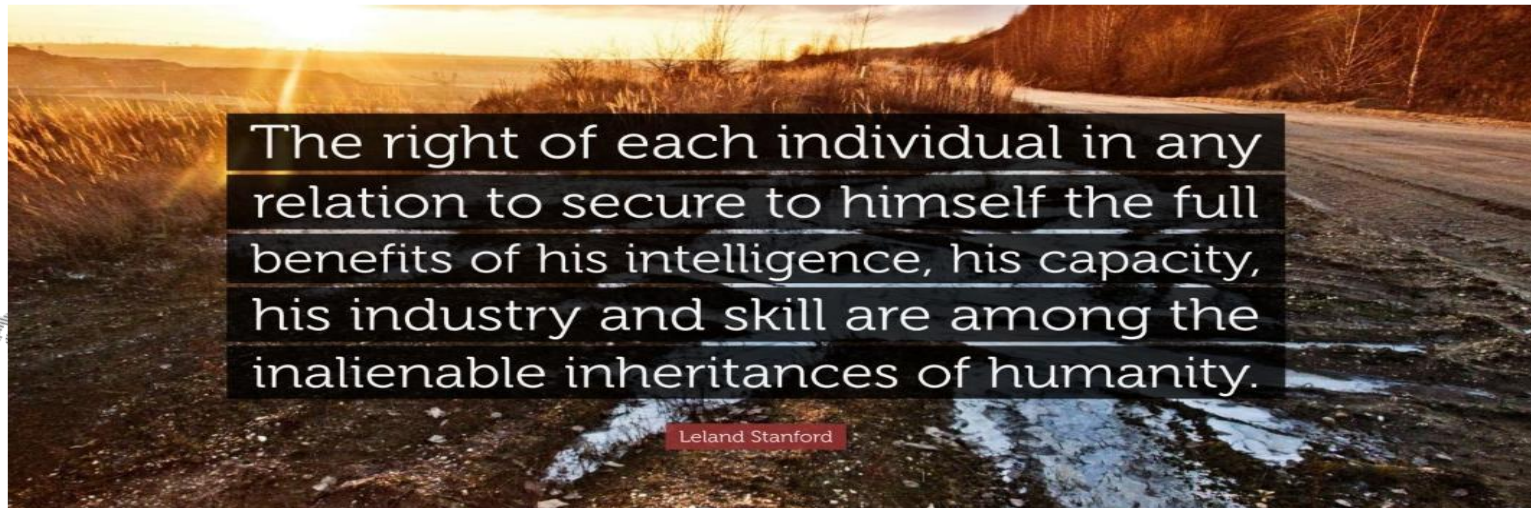
Whom do you secure most? Your Life /  
Yourself



Work Integrated Learning Programmes



# What is Security?



The right of each individual in any relation to secure to himself the full benefits of his intelligence, his capacity, his industry and skill are among the inalienable inheritances of humanity.

Leland Stanford

# Security

---



Security can be defined only relative to the value and risk propositions of the business

‘Security’ is a **relative term**. There is **no absolute scale** of **security** or **insecurity**.

Both terms, ‘secure’ and ‘security’, have a meaning only when interpreted as attributes of something that you consider **valuable**.



# Asset and Vulnerability



## Asset — the thing worth protecting

- **Definition.** anything of value that must be protected — data, software, hardware, services, reputation, people.
- **Why first.** every other term is defined relative to an asset; you cannot judge a threat without asking 'a threat to **what**?'
- **Examples.** customer records, source code, the build pipeline, cryptographic keys, an API's availability.
- **Classification.** assets are ranked by value so effort goes where it matters — protect the crown jewels hardest.

## Vulnerability — a weakness (T2)

- **Definition.** a flaw in an asset's design, implementation, or operation that could be exploited to violate the security policy.
- **It is passive.** a vulnerability causes no harm by itself — like an unlocked door, it is only an opening. Harm needs a threat to act.
- **Sources.** coding bugs, weak configuration, poor design, process gaps.
- **Examples.** the Log4j lookup feature; MOVEit's unparameterised query; a missing MFA.

# Threat and Risk — do not confuse them



## Threat — a potential cause of harm

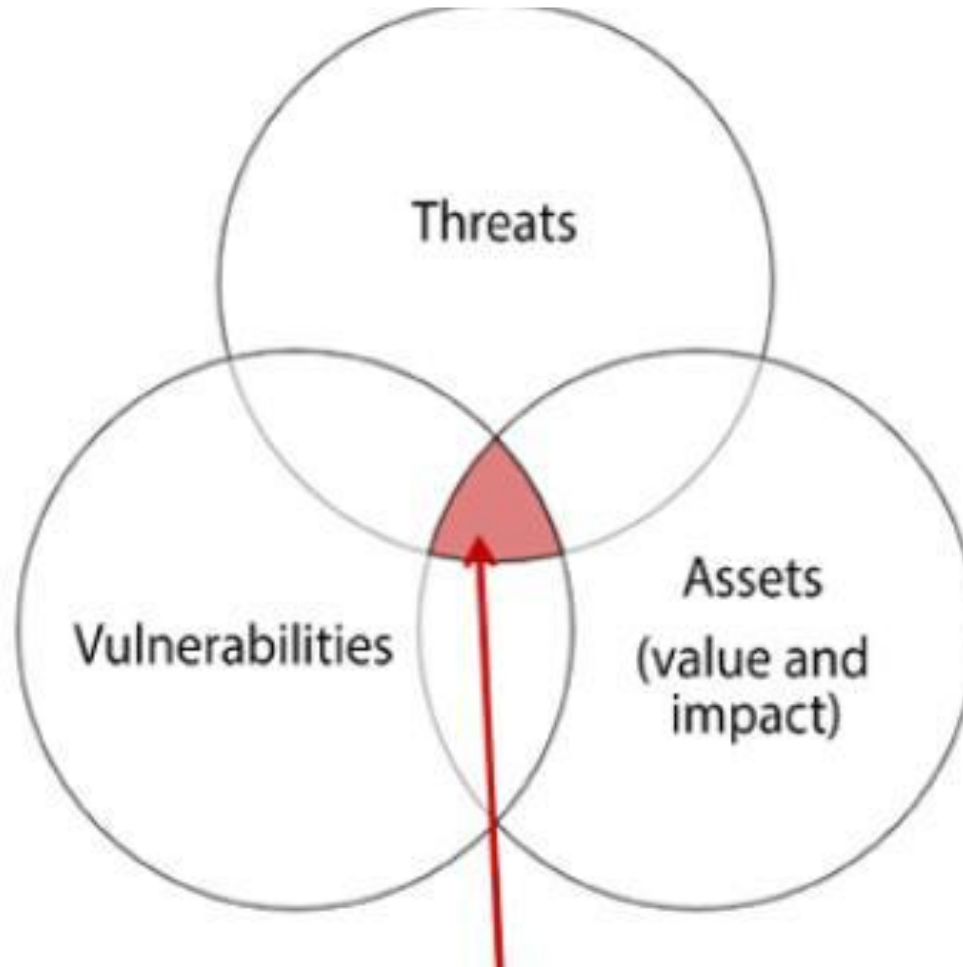
- **Definition.** the potential for a threat agent to exploit a vulnerability; anything with the potential to harm an asset.
- **It is a possibility.** defined by potential, not certainty; may be deliberate (an attacker) or accidental (flood, human error).
- **Threat vs threat agent.** the **agent** is the actor — hacker, insider, malware; the **threat** is the potential they represent.
- **Examples.** the CI0p group; APT29; a careless developer; ransomware; a power cut.

## Risk — likelihood × impact

- **Definition.** the potential for loss when a threat exploits a vulnerability — combining the **likelihood** with the **impact**.
- **Working formula.** Risk  $\approx$  (probability of exploitation)  $\times$  (cost to the owner); often scored Low/Medium/High/Critical.
- **Why it rules practice.** you cannot fix everything, so risk lets you **prioritise**.
- **Example.** an internet-facing SQLi on a payments database is high risk; the same flaw on an isolated test tool is low. Same vulnerability, different risk.



# Definition of Risk



# Exploit — turning potential into reality



- **Definition.** the specific method, code or technique that actively takes advantage of a vulnerability to carry out an attack.
- **Vulnerability vs exploit.** the vulnerability is the weakness; the exploit is the act or tool that uses it. In Log4Shell, the flaw was the vulnerability and the `{jndi:...}` payload was the exploit.
- **Zero-day exploit.** an exploit for a vulnerability with no available patch — the most dangerous kind. Log4Shell and MOVEit both began this way.
- **Proof of Concept (PoC).** a minimal exploit that demonstrates a flaw is real. Once a PoC is public, mass exploitation often follows within hours.
- **Putting the five together.** a threat agent uses an exploit against a vulnerability in an asset — and the risk is the expected loss. Learn that one sentence.

# Threat

---



How is it different from Risk ?



Work Integrated Learning Programmes

---

# Threat

---



A **threat** is anything that can act negatively towards the enterprise assets. It may be a person, virus, malware, or a natural disaster. Due to the broad scope of threats, actions may be purposeful or unintentional in nature adding to the absolute unpredictability of impact. Once a threat is defined, the attributes of threats must be identified and documented. The documentation of threats should include the type of threat, identified threat groupings, motivations if any, and methods of actions.



# Threat Examples



| Data                                                | Threat | Motivations       |
|-----------------------------------------------------|--------|-------------------|
|                                                     |        |                   |
| Credit Card Number<br>Account Information           | Hacker | Theft, Cybercrime |
| Trade Secret                                        |        |                   |
| Company Confidential<br>Documents                   |        |                   |
| Company Client List                                 |        |                   |
| Company Asset<br>Information /<br>Passwords/ Access |        |                   |
|                                                     |        |                   |

# Threat Examples



| Data                                                | Threat     | Motivations                   |
|-----------------------------------------------------|------------|-------------------------------|
|                                                     |            |                               |
| Credit Card Number<br>Account Information           | Hacker     | Theft, Cybercrime             |
| Trade Secret                                        | Competitor | Capture Market /<br>Customers |
| Company Confidential<br>Documents                   |            |                               |
| Company Client List                                 |            |                               |
| Company Asset<br>Information /<br>Passwords/ Access |            |                               |
|                                                     |            |                               |

# Threat Examples



| Data                                                | Threat     | Motivations                   |
|-----------------------------------------------------|------------|-------------------------------|
|                                                     |            |                               |
| Credit Card Number<br>Account Information           | Hacker     | Theft, Cybercrime             |
| Trade Secret                                        | Competitor | Capture Market /<br>Customers |
| Company Confidential<br>Documents                   | Leak       | None                          |
| Company Client List                                 |            |                               |
| Company Asset<br>Information /<br>Passwords/ Access |            |                               |
|                                                     |            |                               |

# Threat Examples



| Data                                                | Threat     | Motivations                   |
|-----------------------------------------------------|------------|-------------------------------|
|                                                     |            |                               |
| Credit Card Number<br>Account Information           | Hacker     | Theft, Cybercrime             |
| Trade Secret                                        | Competitor | Capture Market /<br>Customers |
| Company Confidential<br>Documents                   | Leak       | None                          |
| Company Client List<br>Client Information           | Employees  | Crime                         |
| Company Asset<br>Information /<br>Passwords/ Access |            |                               |
|                                                     |            |                               |

# Threat Examples



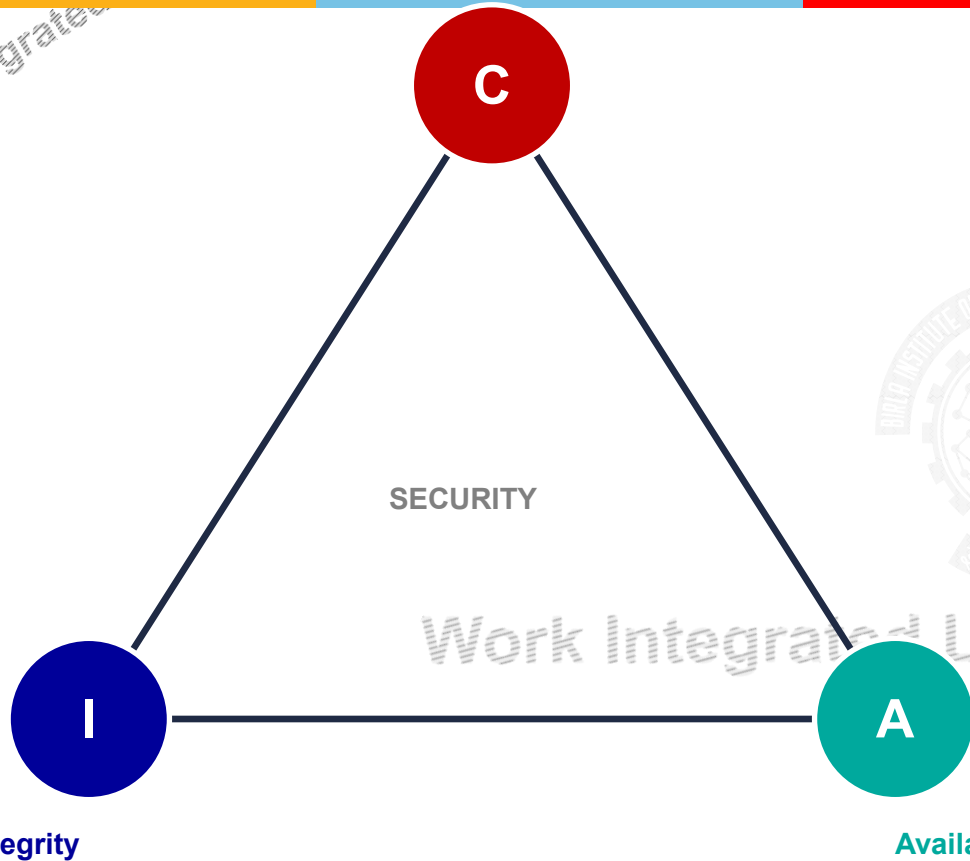
| Data                                                | Threat                   | Motivations                   |
|-----------------------------------------------------|--------------------------|-------------------------------|
|                                                     |                          |                               |
| Credit Card Number<br>Account Information           | Hacker                   | Theft, Cybercrime             |
| Trade Secret                                        | Competitor               | Capture Market /<br>Customers |
| Company Confidential<br>Documents                   | Leak                     | None                          |
| Company Client List<br>Client Information           | Employees                | Crime                         |
| Company Asset<br>Information /<br>Passwords/ Access | Disgruntled<br>Employees | Retaliation<br>Destruction    |
|                                                     |                          |                               |



# The CIA triad — the three goals of security



Confidentiality



- **Confidentiality** — information is disclosed only to those authorised to see it — prevents unauthorised reading or leakage.
- **Integrity** — data and systems remain accurate and unaltered except by authorised parties — prevents unauthorised modification.
- **Availability** — systems and data are usable by authorised parties when needed — prevents denial of legitimate use.

**Note.** The three goals trade off against one another; secure design is a deliberate balance, not the maximum of any one pillar. After any incident, ask which pillar failed.

# CIA in practice — how each pillar is attacked and protected



| Pillar                 | Attacked by                                | Protected by                                  | A real failure                      |
|------------------------|--------------------------------------------|-----------------------------------------------|-------------------------------------|
| <b>Confidentiality</b> | Breaches, sniffing, weak/absent encryption | Encryption, access control, data minimisation | MOVEit — 95M records stolen         |
| <b>Integrity</b>       | Tampering, forged updates, MITM            | Hashing, digital signatures, version control  | SolarWinds — signed update altered  |
| <b>Availability</b>    | DoS/DDoS, ransomware, outages              | Redundancy, backups, rate limiting            | Change Healthcare — pharmacies down |

After any incident, ask which pillar failed — it is the fastest way to classify what went wrong.

# Beyond the triad — properties you must be able to name



| Property               | Meaning                              | Delivered by                       |
|------------------------|--------------------------------------|------------------------------------|
| <b>Authentication</b>  | Verifying an identity is genuine     | Passwords, MFA, certificates       |
| <b>Authorization</b>   | Deciding what an identity may do     | Access control, least privilege    |
| <b>Accountability</b>  | Actions traceable to an entity       | Logging, audit trails              |
| <b>Non-repudiation</b> | A party cannot deny a genuine action | Digital signatures, secure logs    |
| <b>Authenticity</b>    | Data/message/user is genuine         | Signatures, integrity checks       |
| <b>Privacy</b>         | Control over personal data           | Data minimisation, law (GDPR/DPDP) |

Source: Stallings & Brown (T2), Ch 1

# passive versus active attacks



## Passive — observe, do not alter

- Goal: learn information without affecting resources.
- Examples: eavesdropping, traffic analysis, sniffing unencrypted data.
- Hard to detect (nothing changes) — so the emphasis is on **prevention**.
- Primary defence: encryption.

## Active — modify or disrupt

- Goal: alter resources or affect operation.
- Examples: masquerade, replay, message modification, denial of service.
- Hard to prevent completely — so the emphasis is on **detection** and recovery.
- Primary defences: integrity checks, authentication, monitoring.

# Security terminology



| Term                            | Meaning (examination-ready)                                  |
|---------------------------------|--------------------------------------------------------------|
| <b>Security policy</b>          | The rules stating what is and is not allowed for an asset    |
| <b>Countermeasure / control</b> | Something that removes, reduces or detects a threat          |
| <b>Attack surface</b>           | The total set of exploitable points a system exposes         |
| <b>Attack vector</b>            | The specific path used to reach and exploit a target         |
| <b>Defense in depth</b>         | Layered, independent controls, so no single failure is fatal |
| <b>Least privilege</b>          | Every user/process gets the minimum access needed            |
| <b>Residual risk</b>            | The risk that remains after countermeasures are applied      |

# Saltzer & Schroeder — principles of secure design



## The core rules

- **Least privilege.** grant the minimum access needed — limits the damage when something is compromised.
- **Fail-safe defaults.** default to **deny**; access is granted explicitly, never assumed.
- **Economy of mechanism.** keep the design simple and small — complexity hides flaws.

## And three more

- **Complete mediation.** check every access to every object, every time — no cached shortcuts.
- **Open design.** security must rest on secret **keys**, not a secret design — no 'security through obscurity'.
- **Separation of privilege.** require more than one condition to grant access — defence in depth for authority.



# Defense in depth — assume any one control can fail



- **The idea.** multiple, independent, overlapping controls across people, process and technology — like a castle's moat, walls and guards.
- **Why it works.** every control has a failure mode; layering means one breach is not the end — a WAF misses it, least privilege limits it, monitoring catches it.
- **In the case studies.** SolarWinds bypassed prevention (a signed update), yet segmentation and egress monitoring could still have limited and detected it.
- **The mindset.** **assume breach** — design as though attackers are already inside, so each layer contains rather than merely repels.

## Worked exercise — classify the failure by CIA pillar



**Scenario.** For each short scenario, decide which CIA pillar was primarily violated and name one control that would have upheld it.

### Tasks

1. A hospital's patient records are copied and posted on a leak site.
2. An attacker alters bank ledger entries to hide a fraudulent transfer.
3. Ransomware locks a retailer's checkout systems for three days.
4. A signed software update is tampered with before customers install it.

**Answer.** (1) Confidentiality → encryption / access control; (2) Integrity → checksums + access control; (3) Availability → backups / segmentation; (4) Integrity & authenticity → code signing and build-integrity verification.

## Quick check — the vocabulary of security



**Q1. An unlocked door is best described as a...**

(a) threat    (b) vulnerability    (c) risk

**Ans.** (b) Vulnerability — a passive weakness.

**Q2. Risk is best expressed as...**

(a) likelihood × impact    (b) the attacker    (c) a missing patch

**Ans.** (a) Likelihood × impact.

**Q3. A digital signature primarily supports...**

(a) availability    (b) integrity & non-repudiation

**Ans.** (b) Integrity and non-repudiation.

**Q4. Eavesdropping on unencrypted traffic is a...**

(a) passive attack    (b) active attack

**Ans.** (a) Passive attack (defence: encryption).

**Q5. 'Grant the minimum access needed' is the principle of...**

(a) open design    (b) least privilege

**Ans.** (b) Least privilege.